JANET'S QUALITY CATERING

System Limitations

An honest assessment of the system as implemented, separating current limitations from possible improvements.

System	Catering management system (PHP and MariaDB)
Database version	2.8.0 (janets_catering)
Date	November 7, 2026
Intended readers	The owner, administrators, project reviewers and future developers

Contents

1. Purpose and how to read this document
2. Technical limitations
3. Functional limitations
4. Database limitations
5. Security limitations
6. User access and permission limitations
7. Performance limitations
8. File upload limitations
9. Internet and server dependency
10. Automated archiving limitations
11. PDF generation limitations
12. Scalability limitations
13. Possible errors and system constraints
14. Current limitations versus proposed improvements
15. Recommended future enhancements

1. Purpose and how to read this document

This is an honest account of what the system cannot do, or does only in part, as of November 7, 2026. Each item was found in the actual code, database or test results. Features that are fully implemented are not listed as limitations.

In the tables, **Limitation** and **Effect** describe the system today. **Possible improvement** is only a suggestion and has not been built.

Most important items

- **Built-in fallback passwords.** Two accounts can still sign in with passwords whose hashes are written in `config/database.php`, even after their owners change their password on the Profile page. The real Admin and Owner sign in this way today, so these must not be removed until both have set new passwords.
- **Sign-in depends on internet and Gmail.** Every login needs an emailed code, so with no internet or a Gmail failure nobody can sign in.
- **Verification links only open where the system can be reached.** `APP_BASE_URL` is set to `http://localhost/VERANO`, so a link opens only on this computer. On a phone, use the 6-digit code from the same email, or change the setting when the system has a network address.
- **Automatic deletion needs this computer on and signed in.** The scheduled task runs only while the Windows user is logged on and MySQL is running.
- **Deleted records are not gone from every copy.** The Activity Log keeps the old values of deleted bookings and reports, and backups keep full copies.
- **Database password and mail password are in plain files.** MariaDB uses root with no password, and the Gmail App Password is stored in `config/email_config.php`.

2. Technical limitations

Limitation	Effect	Possible improvement
Runs on XAMPP on one computer, with Apache and MySQL started by hand	If either is stopped or the PC is off, the system is unavailable	Host on a dedicated server with services that start automatically
No version control: the project folder is not a Git repository	Changes cannot be traced or rolled back by version	Put the code in Git
No automated test suite. Testing is scripted by hand for each change	A change can break something that was not re-tested	Add automated tests
Pages mix PHP, HTML, CSS and JavaScript. `includes/header.php` is over 2,000 lines, with heavy inline CSS	Slower to maintain, and style changes can have side effects	Move to separate templates and stylesheets
Unused Next.js files remain (`app/`, `package.json`, `next.config.mjs`)	Confusing for a new developer. They do nothing	Remove them
`index.php` is the XAMPP default redirect	Opening the folder address goes to the XAMPP page, not the login page	Redirect it to `login.php`
The GD image library is off	Uploaded pictures cannot be resized or re-encoded	Enable GD or Imagick and resize uploads

3. Functional limitations

Limitation	Effect	Possible improvement
A completed event cannot be reopened	Its status stays Completed. Archiving and restoring returns it to Completed	Add a controlled reopen action
Supervisors cannot change preparation status	The Owner or Admin sets it, as the request listed viewing and monitoring only	Let Supervisors update it if wanted
Payments can be deleted but not edited, and there is no refund workflow	A mistake is corrected by deleting and re-entering. Overpayment is refused	Add voiding and refunds
SOA business details start with the name only	Address, phone and email appear after someone fills them in on the SOA page	Enter them once
Bookings saved before this version had their inclusions copied from the catalogue at update time	If a package changed earlier, the copy shows the catalogue as it stood at the update	None available: the old wording was not recorded
Archiving a booking deletes its payments and files after 30 days with the booking	Payment history then exists only in the Activity Log and older backups. Archive only what should go	Keep payments longer than bookings
An Approved booking opens its survey on the event date, without the Completed button	A client could answer before the event finishes that day	Require Completed only
Survey links are copied and sent by hand	Nothing is sent automatically, and links do not expire	Email the link automatically, with an expiry
Reports are typed by hand	They are not generated from booking or stock figures	Add generated report templates
No self-service password reset on the login page	A user who forgets a password needs direct help	Add an emailed reset
Names allow only the letters A to Z and spaces, as requested	Ñ, accented letters, hyphens, apostrophes and periods are refused: Peña, Niño, Ann-Marie, O'Brien, Jr.	Allow Ñ and these characters if wanted
Postal code check confirms 4 digits only	A well-formed code that does not exist is accepted, and it is not matched to the barangay	Add a postal code reference list
Blocking of bad characters as they are typed was tested with a desktop browser, not on a real phone keyboard	Phone keyboards send text in stages, so a bad character is removed when the word ends rather than at once. The server still refuses it on saving	Test on a real phone
Existing accounts and bookings have no postal code	They show empty until edited, and the edit form then requires one	Enter them once
Customers have no login or upload page	Staff upload the receipt a customer gives them	Add a secure customer upload page
Deleting an archived booking also deletes its receipts	After the 30-day archive period, or a manual delete, the receipt files are gone. The Activity Log keeps the payment details only	Keep receipts when a booking with payments is deleted

Limitation	Effect	Possible improvement
Archive covers accounts, bookings and reports only	Surveys and menu records use their own delete or deactivate actions	Extend the archive if wanted

4. Database limitations

Limitation	Effect	Possible improvement
Old columns and tables remain until checked: `description` and `event_type` on the menu tables, and the Foodstocks tables	They are unused but still take space, and backups include them. `database/optional_cleanup_after_v2_5.sql` removes them	Run the clean-up after checking the results
Some id columns have no foreign key (`created_by`, `archived_by`, `restored_by`, `booking_items.ref_id`, location codes)	The database does not stop a wrong id. The application sets them	Add foreign keys where practical
Contact number format and the name rule are enforced by the application, not the database	Direct changes, such as through phpMyAdmin, can store bad values, though they are logged as direct changes	Add check constraints
Postal code columns allow NULL for older rows	"Required" is enforced by the forms	Make them NOT NULL once all rows are filled
A phone number stays on an account whose credentials were removed	That number cannot be used for a new account, because phone numbers must be unique. The email address is freed	Decide a rule for reusing numbers
`activity_logs` and `notifications` only grow. Logs can never be deleted by design	The database gets larger over time	Plan archiving of old years to separate storage
Status history is kept only in the Activity Log	There is no per-booking history view	Add a booking timeline

5. Security limitations

Limitation	Effect	Possible improvement
Fallback passwords remain (see section 1). Passwords do use bcrypt, but these two hashes are in the source code	Anyone who learns one can sign in with it, subject to the emailed code. Changing the password on Profile does not disable it	After both users set new passwords, limit the fallback to database outages or remove it
During a database outage, the fallback login cannot read the account state	An archived fallback account is only blocked when the database can be read. With no database the system is not usable anyway	Remove the fallback
The fallback route after archiving was checked by reading the code and through normal accounts, not with the real fallback password, which was not available for testing	Low risk, but not proven end to end	Test once with the real password, on a temporary archive
MariaDB uses `root` with no password	Anyone with access to this computer can read everything	Set a password and a limited database user
The Gmail App Password is in plain text in `config/email_config.php`	Anyone who can read the file can send mail as that account	Move it to an environment variable outside the web root
Local use is plain HTTP	Passwords and codes are not encrypted on a network. The cookie becomes Secure automatically under HTTPS	Install a certificate before any network use
No limit on repeated password guesses. Emailed codes are limited to 5 tries	Password guessing is slowed only by the code step	Add lockout or rate limiting
Older Activity Log entries contain emails, and usernames may be emails	Permanent Delete removes the email from the account, and new log entries mask it, but older entries stay because logs are write-once	Decide a privacy policy for old logs
Backups are compressed but not encrypted	Anyone with access to the backup folder can read them	Encrypt backups
No Content-Security-Policy header. Scripts load from outside sites	If a CDN were compromised, its script would run in the pages	Host libraries locally and add a CSP
Uploads are checked for type, size and content, but not scanned for viruses	A harmful picture file that is a valid image would be accepted. Scripts cannot run from the folder	Add scanning if files come from outside staff

6. User access and permission limitations

Limitation	Effect	Possible improvement
Three fixed roles	Permissions cannot be tailored further, for example a kitchen-only user	Add configurable roles
A Supervisor has no Profile page, as they have one module	They can change their password on the dashboard, but cannot edit their name or photo. The Owner has no form for this either	Add it if wanted
Any Admin can archive or remove the credentials of any other Admin	One Admin can lock out another. It is logged. The Owner, Supervisors and the last active Admin are protected	Require Owner approval
Backup & Restore is ADMIN only and Activity Log management is OWNER only	The Owner cannot run backups, and the request also says the Owner has full access. This follows the earlier explicit rule	Change if the Owner should have them
The Owner account cannot be created, archived or changed from Accounts	A replacement Owner needs a database change	Add a controlled ownership transfer
Clients have no accounts	They cannot book or see bookings themselves	Add a client portal
A signed-in user cannot see other active sessions	Sessions end by logout, archive or two idle hours only	Add session management

7. Performance limitations

> No load testing has been done. These points come from how the code works, not from measurements.

Limitation	Effect	Possible improvement
Bookings and Reports load every row, then filter in the browser	Pages will slow as records grow	Add server-side paging and search
Duplicate email checks read all account emails, to compare Gmail variations	Fine for a few staff accounts, not for thousands	Store a normalized email column
Each open dashboard requests data every 15 seconds. Hidden tabs pause	Several open dashboards add steady small load	Use longer intervals or server push
Login and verification email is sent while the page waits	A slow mail server delays the page	Send mail through a background queue
Photos are served at full size (GD is off)	A 10 MB photo downloads in full to show as a small avatar	Resize on upload

8. File upload limitations

Limitation	Effect	Possible improvement
Profile photos: 10 MB; JPG, JPEG, PNG or WebP. Survey and menu photos: 5 MB, and GIF is also allowed	Larger files or other types are refused with a message	Unify if wanted
A file whose extension does not match its real type is refused, for example a PNG renamed .jpg	Users must keep correct file names	None needed
PHP refuses requests above 40 MB (`post_max_size`)	The whole request is discarded. A clear message is shown	None needed
Uploaded files are not in database backups	After a disaster, photos, receipts and attachments must be restored separately from the `uploads/` folder. Payment rows would point at missing receipts otherwise	Include uploads in backups
Files stay on the local disk. Photos of archived accounts stay	Disk use grows, and there is no second copy	Use backed-up storage

9. Internet and server dependency

Needs	If unavailable
Apache and MySQL running	The system does not open
Internet and Gmail SMTP	No login codes or verification codes, so **nobody can sign in**. Existing sessions keep working
cdn.jsdelivr.net (Bootstrap, Boxicons, SweetAlert2, Chart.js)	Pages lose styling, dialogs and the dashboard chart. Confirmation dialogs depend on SweetAlert2, so actions using them cannot be confirmed
fonts.googleapis.com	A fallback font is used. Nothing breaks
cdnjs.cloudflare.com (Font Awesome, and html2canvas and jsPDF for bookings)	Booking Save as PDF tells the user to use Print. **Report PDF is not affected**: its library is stored in the project

Possible improvement: store all libraries in the project, and allow a recovery sign-in that does not need email.

10. Automated archiving limitations

Limitation	Effect	Possible improvement
The Windows task is "Interactive only": it runs only while this Windows user is signed in	If nobody is signed in, deletion waits	Set the task to run whether or not a user is logged on, or use a server cron job
It also needs the PC on and MySQL running	Missed runs do not lose work: the next run deletes everything overdue. Records may stay longer than 30 days	Run on an always-on server
Runs hourly	A record may be deleted up to about an hour after its 30 days end	Run more often if needed
The run writes no log file, and a run that cannot reach the database records nothing	The archive pages warn when the last run is over 26 hours old. Nothing alerts anyone who does not open them	Send an email alert
Moving to another computer or Linux needs the task set up again	Without it nothing is deleted, and the warning appears	`cli/register_scheduled_task.bat` or a cron line, as in the script header
Permanent deletion cannot be undone from the system	Recovery means restoring a whole backup, which also undoes later changes	Add restore of single records
Old values of a deleted record stay in `activity_logs`, and full copies stay in older backups	"Permanently deleted" applies to the live tables only. This matters if there is a privacy duty to erase data	Set retention for logs and backups

11. PDF generation limitations

Limitation	Effect	Possible improvement
Report PDF uses built-in Latin fonts	Western European letters such as Ñ work. ₱ prints as "PHP", curly quotes and dashes become plain ones, and other symbols or scripts become "?". Print shows them correctly	Embed a Unicode font
Booking details PDF is an image of the page. The Statement of Account PDF is text	The details PDF cannot be searched, and it needs internet the first time on a page	Rebuild it as a text PDF
PDFs are created in the browser, one at a time, and not stored	There is no batch export, and no server copy	Add server-side generation
The browser's print dialog could not be exercised by automated testing. Print content and layout were checked	Please try one real print on your printer	Manual check
Print and PDF results depend on the browser	Layout was checked in Microsoft Edge only	Check in other browsers
These three documents are snapshots	They do not update when the system changes	Regenerate after major changes

12. Scalability limitations

Limitation	Effect	Possible improvement
One server holds the application, database, uploads and backups	A disk failure could lose all of them, including backups	Keep backups on another machine
Sessions and uploads are local files	The system cannot be spread across several servers as it is	Use shared session and file storage
No caching or background jobs	All work happens during the request	Add a job queue and caching
Notifications create one row per Admin or Owner for each event	Rows grow with both activity and staff numbers	Summarize or expire old notifications
Designed for a small staff	Suits a single catering business. Multiple branches are not supported	Add branches if the business grows

13. Possible errors and system constraints

What the user sees	Likely cause	What to do
"We could not send the verification email"	No internet, Gmail refused, or App Password changed	Check internet and `config/email_config.php`
"Your session security token expired"	The page was open too long, or was signed out in another tab	Reload and try again
Signed out with "two hours of inactivity"	No page opened for two hours	Sign in again
"This account has been archived"	Account was archived	Another Admin or the Owner can restore it, unless its credentials were removed
"Enter exactly 10 digits after +63"	Number has a leading 0, wrong length, or other characters	Enter 10 digits starting with 9
"can contain letters and spaces only"	Name has a digit, hyphen, apostrophe or period	Remove the character
"Postal code must be exactly 4 digits"	Wrong length, or letters	Enter 4 digits
"The picture must be 10 MB or smaller"	File too large	Use a smaller photo
"Only valid JPG, PNG, WebP images are accepted"	Wrong type, or extension does not match the content	Save the picture in an accepted format
"The upload is larger than the server allows"	Request above 40 MB	Use a smaller file
"Another active booking already holds this venue, date and time"	Slot is taken	Change the time or venue, or cancel the other booking
"The automatic clean-up last ran on..."	Task disabled, user signed out, PC off, or MySQL stopped	Check Task Scheduler and XAMPP
Page unstyled, or buttons without dialogs	No internet for CDN libraries	Restore internet
Database connection failed	MySQL not started	Start MySQL in XAMPP

14. Current limitations versus proposed improvements

Area	Today	Proposed	Priority
Fallback passwords	Work alongside real passwords	Set new passwords, then remove	High
Secrets	Empty root password; App Password in a plain file	Database password; secrets outside the web root	High
Login dependency	Internet and Gmail required	Recovery sign-in; password reset	Medium
Scheduled task	Only while the user is signed in	Run whether signed in or not	Medium
Password guessing	No lockout	Rate limiting	Medium
Hosting	Single PC over HTTP	Server with HTTPS and off-site backups	Medium
Refunds	Overpayment refused, no refund records	Refund workflow	Medium
Lists	All rows loaded	Server-side paging	Low until data grows
Booking PDF	Image-based, needs internet	Text PDF with a local library	Low
Report PDF symbols	Latin characters only	Embedded Unicode font	Low

15. Recommended future enhancements

Do first

- Have the real Admin and Owner set new passwords, then retire the fallback logins.
- Set a MariaDB password, and move the mail password out of the project folder.
- Run the optional clean-up script once the update has been checked.
- Put the project under version control.
- Correct `index.php`, and remove the unused Next.js files.

Do next

- Move to always-on hosting with HTTPS, and run the clean-up task without needing a signed-in user.
- Add a password reset, rate limiting, and an alert when the clean-up stops.
- Include uploads in backups, and copy backups off the machine.
- Add refunds, and keep payment history longer than archived bookings.

Later

- Generated reports from live data.
- Automatic survey emails, with expiring links.
- Client portal.
- Configurable roles.
- Server-side paging, image resizing, and a booking timeline.
- Automated tests.